

I1: Excessively Privileged Application

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1611: Escape to host T1098: Account Manipulation	
	Mitigations	M0926: Privileged Account Management	
Affected Scope			

Description

The **API** service is running as a privileged user, significantly increasing the effectiveness of chain exploits. An attacker running commands will end up running those commands as privileged user, giving them increased access and permissions to backend files and services.

Business Impact

If exploited the **SERVICE** service, a user will immediately have privileged access on the backend system. This misconfiguration significantly increases the criticality of any other vulnerability, by being run as an excessively privileged user.

Steps to Reproduce

- Step 1: Check what user is running the program by running “ps -p XXX”
Step 2: Check the users' permissions by running “id user”

Remediations

Team-XX recommends the following:

1. Implement the Principle of Least Privilege so that non-privileged system accounts have only the minimum permissions required to function.
2. Creating service accounts with limited access, following the Principle of Least Privilege.
3. Regularly audit permissions to ensure no privilege creep occurs over time.

References

[CrowdStrike - Principle of Least Privilege](#)

I1: Anonymous FTP login

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1105: Ingress Tool Transfer T1570: Later Tool Transfer T1048: Exfiltration Over Alternative Protocol	
	Mitigations	M1022: Restrict File and Directory Permissions M1035: Limit Access to Resource Over Network	
Affected Scope			

Description

Anonymous FTP login is permitted on the internal FTP server. This allows any unauthenticated user to view any internal files that are not restricted to specific users on the FTP server.

Business Impact

If the FTP server is utilized to serve sensitive files and data, attackers are easily able to anonymously log in and view the data on the FTP server. Attackers can also abuse the FTP server to get exploitation tools into the internal network and exfiltrate sensitive data out of the internal environment which is harder to detect and prevent than other infiltration/exfiltration methods.

Steps to Reproduce

Step 1: Log into FTP server with anonymous username and any password

Step 2: Use the ls command to view data and files stored on the FTP server

Step 3: Use put to transfer exploitation tools and scripts into the internal network

Remediation Strategies

Team-XX recommends the following:

1. Disable anonymous FTP login if there is no explicit reason to require it.
2. If anonymous FTP is required, it is recommended that anonymous users do not have access to any sensitive information and files that should not be publicly accessible. It is also recommended to disallow anonymous users from being able to upload any files to the FTP server.

References

[IBM - FTP Security](#)

I1: SMB Share Guest Access

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		

CVSSv4.0 Attack Vector		N/A
MITRE ATT&CK	Techniques	T1021.002: Remote Services: SMB/Windows Admin Shares T1105: Ingress Tool Transfer T1048: Exfiltration Over Alternative Protocol
	Mitigations	M1022: Restrict File and Directory Permissions M1035: Limit Access to Resource Over Network
Affected Scope		

Description

Guest SMB Access is permitted on the internal SMB server. This allows any unauthenticated user on the network to connect and view any internal files without needing to provide valid credentials.

Business Impact

If the internal SMB server is utilized to serve sensitive files and data, attackers are easily able to anonymously log in and view the data on the SMB server. Attackers can also abuse the internal SMB server to get exploitation tools into the internal network and exfiltrate sensitive data out of the internal environment which is harder to detect and prevent than other infiltration/exfiltration methods.

Steps to Reproduce

Step 1: Log into SMB server with no username and no password

Step 2: Use the ls command to view data and files stored on the SMB server

Step 3: Use put to transfer exploitation tools and scripts into the internal network

Remediation Strategies

Team-XX recommends the following:

1. Disable Guest SMB authentication via the **Group Policy** to enable enforcement for the entire domain. Navigate to 'Computer Configuration\Administrative Templates\Network\Lanman Workstation' and set "**Enable insecure guest logons**" to **Disabled**.

2. Ensure that all shares are configured with explicit permissions that allows access on the basis of principle of least privilege, allowing only authorized users and groups to connect.

References

[Microsoft - SMB security hardening](#)

[Absolute - Disable Guest Logons](#)

I1: Exposed API Documentation

M0800 Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	TA0043: Reconnaissance T0871: Execution Through API	
	Mitigations	M0801: Access Management M0800: Authorization Enforcement	
Affected Scope			

Description

API documentation is publicly exposed allowing attackers to view what API calls can be made when going to the HTTP page. Attackers can abuse this to be able to learn what API calls are possible and how to execute API calls such as being able to read internal files on the host server.

Business Impact

API documentation being publicly exposed allows attacker to view what API calls can be made and retrieve internal documents and files that can be used to

exfiltrate data and gain sensitive information such as personal information or network credentials.

Steps to Reproduce

Step 1: Go to the HTTP webpage

Step 2: Go to the following **PAGE** based on the API documentation

Remediation Strategies

Team-XX recommends the following:

1. Remove or relocate API documentation if not strictly necessary
2. Implement authentication on API documentation endpoints to ensure that only authorized users can access documentation

References

[Speakeasy - Exposing your API publicly](#)

I1: Outdated TLS Version

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1562-010 - Downgrade Attack	
	Mitigations	M1051 - Update Software	
Affected Scope			

Description

The installed TLS version used in APPLICATION has an outdated version; the latest TLS version is 1.3, while the application uses TLS VERSION. An attacker can potentially exploit this outdated version, possibly in combination with other exploits, to gain access to information or systems that they should not be able to.

Business Impact

An attacker could potentially exploit an outdated TLS version to carry out a downgrade attack or other similar exploits, which could allow decryption of traffic. Traffic decryption allows reading information such as passwords in plaintext, which can cause severe security issues. Furthermore, having an outdated TLS version can cause compliance issues with e.g. the PCI DSS.

Steps to Reproduce

Step 1: Use sslscan to check the TLS version. sslscan IP

Remediation Strategies

Team-XX recommends the following:

1. Modify configurations to support the newest TLS version available (TLSv1.3)

References

[Microsoft - Solving the TLS1 problem](#)

[Trace Security - Disabling deprecated TLS protocols](#)

I1: User Enumeration Through Failed Login

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1087 - Account Discovery	
	Mitigations		
Affected Scope			

Description

Upon credentials being entered, the **sign-in/register** page issues a different response based on whether or not an account with the provided name already exists. This means it's possible for an attacker to determine whether or not a user exists, making it possible to enumerate users.

Business Impact

This is not a significant issue in and of itself, but exploiting this functionality in order to enumerate users (likely with a word list) is useful in chain attacks, as, for example, an attacker could determine the exact name of an admin account, and then try to brute-force the password of that account with this information.

Steps to Reproduce

Step 1: Go to **PAGE**

Step 2: Enter a random username with any arbitrary password

Step 3: Enter an existing username with any arbitrary password

Step 4: Observe the response being different

Remediation Strategies

Team-XX recommends making it non-obvious that an account already exists when trying to log in to it, which would prevent such easy enumeration.

References

I1: Deprecated Windows Server Version

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1595: Active Scanning	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The identified hosts are running Windows Server 2016, an operating system that longer be supported with regular security updates by Microsoft after 2027. This means that future vulnerabilities won't be patched, and can be exploited by attackers.

Business Impact

In the future, as new vulnerabilities are discovered, this can be an issue to the company as much of the core infrastructure uses Windows Server 2016. If these machines are compromised, the operational integrity of the entire network will be in danger, possibly leading to loss of life.

Steps to Reproduce

Step 1: Use enum4linux-ng to scan the host

enum4linux-ng-A hostname

Step 2: Observe the Operating System Version to be Windows Server 2016

Remediation Strategies

Team-XX recommends the following:

1. Update all servers running Windows Server 2016 to the latest version of Windows Server 2022

References

[Microsoft - Windows Server 2016 Lifecycle](#)

I1: Internet Explorer Enabled

M0800 Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Low		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	N/A	
	Mitigations	M1042: Disable or Remove Feature or Program	
Affected Scope			

Description

Internet Explorer is still installed and enabled on the **Domain Controller**. Internet Explorer has retired from Microsoft and has stopped receiving all updates as of 2022.

Business Impact

Internet Explorer is an outdated and unsupported Microsoft program installed on the **Domain Controller**. While no current critical vulnerabilities are known for Internet Explorer, any newly discovered exploits will not receive security patches and would leave the machine open to attacks.

Steps to Reproduce

Step 1: Browse installed programs

Step 2: See Internet Explorer

Remediation Strategies

Team-XX recommends the following:

1. Uninstall Internet Explorer on all Windows machines to reduce the attack surface on the network.

References

[Microsoft - Internet Explorer End-Of-Life](#)

I1: Information Disclosure Through Error Message

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	N/A	
	Mitigations	M1054 – Application Isolation and Sandboxing M1051 - Update Software	
Affected Scope			

Description

The web application reveals sensitive information from its error messages revealing X. This information should not be publically exposed as it provides attackers with information that could be used to do X.

Business Impact

Exposing detailed error messages increases the application's attack surface and attackers can use this to perform targeted attacks on X. This can lead to unauthorized access, theft of sensitive information, and damage to APT's reputation.

Steps to Reproduce

Step 1: Enter X into the web application to trigger an error message.

Step 2: Observe the error message returned by the application and see that it reveals X.

Remediation Strategies

Team-XX recommends the following:

1. Hide error messages and display generic error messages that do not reveal internal technical details.

2. Disable debug mode to prevent the leakage of diagnostic information.
3. Audit the applications error handling regularly and keep all software components up to date.

References

[OWASP - Improper Error Handling](#)

[PortSwigger - Information disclosure vulnerabilities](#)